

Reporte Ejecutivo de Gestión de Riesgos

Registro inicial de riesgos de seguridad de la información · Septiembre de 2026
Elaborado por el Responsable de Seguridad de la Información

1 Resumen ejecutivo

Tras la auditoría externa que identificó debilidades en la gestión de riesgos, se elaboró el primer registro formal de riesgos de seguridad de la información de la clínica. El análisis abarcó once activos críticos, identificó diecisiete escenarios de amenaza y los consolidó en **ocho riesgos**.

8 RIESGOS IDENTIFICADOS	4 DE NIVEL CRÍTICO	3 PLANES DE ACCIÓN	23.300 INVERSIÓN ESTIMADA USD
----------------------------	-----------------------	-----------------------	----------------------------------

La mitad de los riesgos identificados alcanza nivel **Crítico**, lo que exige acción inmediata según los criterios adoptados. Dos de ellos comprometen información de pacientes; los otros dos, la continuidad de la atención.

El hallazgo de mayor relevancia para la toma de decisiones no es la cantidad de riesgos, sino su **interdependencia**. Las debilidades detectadas se encadenan: la imposibilidad de saber quién accede a cada historia clínica no solo permite el acceso indebido, sino que impide detectarlo. La falta de verificación de las copias de respaldo convierte cualquier incidente recuperable en pérdida definitiva. Esto tiene una consecuencia favorable: **atender un número reducido de riesgos produce mejoras simultáneas en varios frentes**.

Naturaleza de la amenaza externa

Conviene precisar ante el Directorio qué tipo de adversario enfrenta la clínica. La red inalámbrica de la sala de espera carece de contraseña y comparte segmento con los sistemas administrativos: cualquier persona sentada allí se encuentra, técnicamente, dentro del perímetro de confianza. La amenaza no llega desde internet; **llega caminando y toma asiento en la sala de espera**, indistinguible de un paciente. Es la situación del cuento de Caperucita Roja: el lobo feroz no fuerza la puerta, sino que se presenta con la apariencia de alguien esperado y es admitido sin verificación. La defensa perimetral existe, pero se apoya en un supuesto de confianza que hoy no se verifica.

2 Los cinco riesgos de mayor exposición

ID	RIESGO	VALOR	NIVEL	CONSECUENCIA PRINCIPAL
R04	Acceso indebido a datos de pacientes por personal interno o egresado	20	Crítico	Exposición irreversible de información médica; responsabilidad legal directa
R06	Pérdida de capacidad de recuperación ante un incidente	20	Crítico	Pérdida definitiva de historias clínicas, no reconstruibles
R01	Pérdida de integridad de los datos clínicos y administrativos	16	Crítico	Decisiones asistenciales sobre información errónea
R03	Pérdida de trazabilidad por uso de credenciales ajenas	16	Crítico	Imposibilidad de acreditar quién accedió a cada historia clínica
R05	Interrupción del servicio por falla, saturación o daño del servidor	15	Alto	Paralización de la atención de 800 pacientes diarios

Los tres riesgos restantes —acceso no autorizado a la red interna, exposición de los puestos de trabajo y debilidad de los controles de autenticación— se sitúan en niveles Alto y Medio, y se abordan en el registro completo.

3 Estado de los planes de acción

PLAN	OBJETIVO	RIESGO	VENCIMIENTO	PRESUPUESTO	ESTADO
PA-01	Restablecer la capacidad de recuperación ante incidentes	R06	15/12/2026	USD 4.500	Planificado
PA-02	Restituir la trazabilidad de accesos al sistema	R03	31/01/2027	USD 6.800	Planificado
PA-03	Control de acceso bajo mínimo privilegio	R04	31/03/2027	USD 12.000	Planificado

Los tres planes se encuentran **en estado Planificado**, a la espera de aprobación presupuestaria por parte del Directorio. Su secuencia no es arbitraria: PA-02 constituye condición previa de PA-03, dado que registrar quién consulta cada historia clínica carece de valor probatorio mientras no pueda garantizarse que cada credencial corresponde a una única persona.

Efecto esperado sobre el perfil de riesgo

NIVEL	SITUACIÓN ACTUAL	TRAS EL PLAN DE TRATAMIENTO
Crítico	4	0
Alto	3	3
Medio	1	4
Bajo	0	1

La ejecución completa del plan **elimina la totalidad de los riesgos de nivel Crítico**. Se advierte que ningún plan reduce el riesgo a cero: los tres que permanecen en nivel Alto conservan un componente que ningún control elimina, como la conducta del personal con acceso legítimo a la información que consulta.

El enfoque de tratamiento: tres capas de defensa

Las salvaguardas propuestas no descansan sobre una única barrera, y la razón es la misma que ilustra el cuento de los tres cerditos: la casa de paja y la de madera ceden ante el primer embate, mientras que la de ladrillo resiste. La diferencia no está en la intención sino en la solidez del material, y ninguna de las tres protege si el lobo entra por otra vía.

El plan combina, en consecuencia, **tres tipos de salvaguarda que operan en capas sucesivas**. Las **administrativas** —políticas, capacitación, procedimientos de alta y baja de personal— son las de menor costo y funcionan mientras se sostengan en el tiempo. Las **técnicas** —segmentación de red, segundo factor de autenticación, registro de auditoría, perfiles de mínimo privilegio— no dependen de la disciplina individual y constituyen la capa de ladrillo del esquema. Las **físicas** —reubicación del equipamiento, respaldo eléctrico, copias fuera del edificio— protegen frente a aquello que ninguna configuración puede evitar. Una capa sola es insuficiente; la protección efectiva resulta de las tres actuando en conjunto.

4 Recomendaciones prioritarias

1 Verificar la capacidad de recuperación antes que cualquier otra medida

Las copias de respaldo de la clínica nunca fueron restauradas. Su funcionamiento no es un hecho comprobado sino una suposición, y la única circunstancia en que se verifica es aquella en que se las necesita, cuando la falla ya resulta irreparable. Ninguna otra inversión en seguridad tiene sentido mientras no se confirme que la información puede recuperarse. Es la recomendación de menor costo y mayor urgencia del plan.

2 Segmentar la red interna y proteger el acceso inalámbrico

Es la medida de mejor relación entre efecto y costo. Separar la red de pacientes de la de los sistemas administrativos resuelve un riesgo completo y reduce simultáneamente el impacto de otro, sin requerir modificación alguna sobre el sistema de gestión clínica.

3 Restituir la trazabilidad de los accesos

Sin capacidad de atribuir cada acción a una persona determinada, la clínica no puede investigar incidentes, aplicar medidas correctivas ni acreditar el cumplimiento normativo ante una auditoría o un reclamo judicial. En el ámbito de la salud, demostrar quién accedió a qué información no es una comodidad operativa sino un requisito exigible.

4 Emplazar el equipamiento crítico según criterios técnicos

La ubicación actual del servidor no responde a criterio técnico alguno. Como recomendación permanente, **los centros de datos y el equipamiento de servidores nunca deben situarse contiguos a cocinas ni en posición inferior respecto de piletas o instalaciones sanitarias**, por el riesgo de incendio e inundación respectivamente. Se recomienda su reubicación a un ambiente adecuado, con detección de incendio y respaldo eléctrico.

5 Formalizar el ciclo de vida de las cuentas de usuario

Las credenciales del personal que se desvincula permanecen activas por no existir un procedimiento formal de baja. Incorporar la revocación como paso obligatorio del egreso es la medida de menor costo del plan y elimina un vector completo de acceso indebido. Corresponde implementarla como deshabilitación y no como eliminación de la cuenta, a fin de preservar el registro histórico de la actividad de esa persona.

Consideración final para el Directorio

El perfil de riesgo actual no responde a un incidente puntual sino a la ausencia generalizada de controles: dos de los ocho riesgos identificados no cuentan con ninguna medida de protección vigente. Los controles existentes, allí donde los hay, son parciales. El caso del portal de acceso resulta ilustrativo: se trata de una protección correctamente concebida —solo accesible desde la red interna— cuya eficacia queda anulada porque esa red interna admite a cualquiera que se conecte al wifi de la sala de espera.

La inversión propuesta, de USD 23.300, debe evaluarse contra la exposición que evita: la divulgación de información médica de pacientes es irreversible y habilita responsabilidad legal directa de la institución, mientras que la pérdida definitiva de historias clínicas comprometería la continuidad asistencial y el respaldo documental de la actividad médica realizada.

Documento elaborado a partir del registro de riesgos gestionado en SimpleRisk. El análisis completo, con la justificación de cada valoración, el inventario de activos, las amenazas identificadas y las salvaguardas propuestas, se encuentra disponible para consulta del Directorio.